AI ETHICS, GOVERNANCE AND LEGAL COMPLIANCE ASSESSMENT

SecureFinance Africa: AI-powered identity verification, fraud detection and financial risk assessment platform

Firdaws Mohammed · 2026/AICDF/16701
AI-Driven Cybersecurity and Digital Forensics Fellowship
Repository

1. Executive summary

This report assesses SecureFinance Africa's planned AI platform before deployment. The platform has three modules: M1 identity verification, M2 fraud detection and M3 automated financial risk assessment. I assessed ethical risks, designed governance around the NIST AI Risk Management Framework, analysed binding and non-binding legal instruments, and tested fairness on a synthetic dataset.

Recommendation: a conditional, staged go.

i. **M3:** shadow mode only, with no customer-facing decisions, until its equal-opportunity gap passes a threshold set in advance by the AI Governance Committee, measured on outcome-labelled data.

ii. **M1 and M2:** pilot in Nigeria only after the seven launch gates in Appendix B are met.

iii. **EU expansion:** no-go until Legal confirms how the EU AI Act classifies M3 and the design meets the high-risk requirements ahead of 2 December 2027.

Four findings drive this. First, six ethical risks (bias, proxies, privacy, transparency, rubber-stamp oversight and false-positive harm) are each rated High before controls. Second, the 12-risk register holds seven Critical risks before controls and none after, but only if proposed controls that do not yet exist are built and work. Third, in Nigeria binding data protection duties apply from launch, including a data protection impact assessment filed with the regulator, while the EU AI Act applies only if its territorial triggers are met. Fourth, in the synthetic test the baseline M3 model approved creditworthy rural customers 12.3 percentage points less often than urban ones (95% interval 8.5 to 16.4); training on

repayment outcomes cut the gap to 1.2 points.

Limitations: only M3 was fairness-tested and the data is synthetic with planted bias,.

2. System scope and assumptions

M1 matches an identity document to a live selfie and checks identity databases, so onboarding is approved, delayed or rejected. M2 scores transactions and account behaviour, so transactions may be blocked or accounts frozen. M3 combines profile, behaviour and transaction history into a risk tier with recommended limits, eligibility and pricing. The system *recommends* and staff are expected to review, so I test whether that review is meaningful. Data processed includes identity attributes, biometric images, device and location data and transaction records.

Key assumptions: A1 SecureFinance is established in Nigeria and acts as controller, AI provider and its own deployer. A2 M3 is treated as evaluating creditworthiness, since it sets limits, eligibility and pricing; M1 (one-to-one verification) and M2 (fraud detection) are likely outside the EU's high-risk list. A3 Customers include people with thin credit files or no formal documents. A4 Phase 1 is a Nigerian launch with Nigerian residents; Phase 2 is an EU offering to people located in the EU. A5 The assessment is pre-deployment, so controls are proposed, not existing. Sector financial regulation and GDPR are acknowledged but outside the approved resource set.

3. Key ethical risks

I walked each module through the AI lifecycle and tested it against NIST SP 1270's bias categories and the UNESCO values. UNESCO is non-binding, so it serves as a benchmark here. Where harm is called plausible, it is a hypothesis to test, not a demonstrated fact. Table 1 summarises the six risks.

Table 1: Key ethical risks ER1 to ER6: cause, who is harmed and the proportionate control

Risk	Cause	Who is harmed and how	Proportionate control
ER1 Biased data (bias)	Unrepresentative or historically skewed training data, e.g. thin files, regions with little data	Under-represented customers face more rejections and higher scores	Document data coverage by group; group-gap thresholds as a go-live gate; non-automated onboarding route
ER2 Proxy variables (fairness)	Location, device or language features stand in for protected traits; removing protected attributes is not enough	Customers in some regions or on cheaper devices are flagged as risky	Proxy-risk review before each release; test several fairness measures; protected attributes kept for audit only
ER3 Excess data use (privacy)	Biometric and behavioural data collected, kept or reused beyond need	All customers; biometrics cannot be reissued after a breach	Minimisation, fixed retention, separate encrypted biometric store, purpose limits, DPIA before launch
ER4 Opaque decisions (transparency)	Complex models give a flag with no usable reason	Customers cannot correct errors; staff cannot spot bias	Plain-language reason codes, notice of AI use, named appeal route, decision logs
ER5 Rubber-stamp review (oversight)	Alert volumes, time targets and trust in scores make reviewers accept output by default	Errors pass unchallenged; accountability blurs	Track override rates; automation-bias training; documented human determination for severe decisions
ER6 False-positive harm (fairness)	Fraud controls tuned to avoid missed fraud block legitimate customers	Low-income and unbanked customers lose access to money	Graduated responses before freezes; dispute service target; false-positive rate by group

The risks interact. Unrepresentative data (ER1) and proxies (ER2) raise false positives for some groups (ER6), while weak explanation (ER4) and rubber-stamp review (ER5) stop those errors being caught, so the controls are designed as a package.

4. Governance and risk register

SecureFinance adopts the NIST AI RMF 1.0 as its governance backbone. The framework is voluntary, so adopting it is a management choice that organises how legal duties are met and evidenced.

i. **Govern:** the CEO owns risk appetite, accepts residual High risks and takes the final go/no-go. An AI Governance Committee chaired by the Chief Risk Officer, with Legal, the Data Protection Officer, the CISO, Data Science and Customer Operations, signs off launch gates and model changes. An independent analyst reports to the Committee.

ii. **Map:** document purposes, settings and affected groups; map impacts per module; map third-party components; design where reviewers sit and what they can override.

iii. **Measure:** selection rate, true and false positive rates by group, precision and recall, reason-code coverage, override rates and appeal outcomes. The Committee fixes acceptable group gaps before testing.

iv. **Manage:** a documented go/no-go, prioritised treatment of Critical risks, a tested switch-off procedure and monitoring from daily alert volumes to quarterly independent reviews, with a full re-test on every model change.

Human oversight scales with consequence. Low-risk reversible decisions are automated and sampled. Adverse reversible ones (step-up verification, a temporary limit) show the reviewer the reason code and allow override. Severe or hard-to-reverse ones (account closure, sustained freeze, onboarding rejection) need a documented human determination before action, consistent with UNESCO paragraph 26.

Incident escalation uses four severities. S1 Critical covers a biometric breach, systematic wrongful freezes or discrimination at scale, and notifies the CRO, CEO, DPO and Legal immediately, with suspension considered. S2 High, such as a fairness threshold breach, goes to the Committee chair the same day. S3 and S4 are handled by owners within days or the next review cycle. Under the Nigeria Data Protection Act a breach likely to risk individuals' rights must be notified to the regulator within 72 hours (s.40), so the S1 runbook starts that clock.

The register has 12 risks, each with description, likelihood, impact, owner, control and residual rating (full table in Appendix A, Table 6). The highest-scoring risks are in Table 2.

Table 2: Highest-scoring risks in the AI risk register, with inherent and residual ratings

ID	Risk	Owner	Inherent	Residual
RR01	Error rates differ across customer groups (biased or unrepresentative data)	Head of Data Science	16 Critical	8 Medium
RR02	Proxy features reproduce discrimination	Head of Data Science	16 Critical	8 Medium
RR05	Reviewers accept outputs by default (automation bias)	Fraud Operations Manager	16 Critical	9 Medium
RR06	False positives freeze legitimate customers, with slow remedy	Head of Customer Operations	16 Critical	9 Medium
RR03	Excessive collection, retention or reuse of biometric and financial data	Data Protection Officer	15 Critical	8 Medium
RR08	Compromise of the biometric store or spoofed identity checks	CISO	15 Critical	8 Medium

Residual risk needs a caveat. The fall from seven Critical risks to none is a planned result. It holds only if every proposed control is built and works, and none exists yet, so the residual column is a target to verify at each launch gate, not a measured outcome. RR05 and RR06 stay highest after controls because they depend on reviewer behaviour and customer circumstances that controls reduce but cannot remove.

5. Legal and regulatory assessment

Binding law and voluntary principles are separated in Table 3. Binding instruments create duties only where their scope is triggered; the soft-law instruments never do.

Table 3: Binding and non-binding instruments and when each affects SecureFinance Africa

Instrument	Status	When it affects SecureFinance
Nigeria Data Protection Act 2023 (NDPA), with the NDPC's General Application and Implementation Directive 2025 (GAID)	**Binding** (Nigeria). The GAID is subordinate to the Act	From Phase 1. Under s.2(2) the Act applies where the controller operates or processes in Nigeria; assumption A1 meets this
EU AI Act, Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744	**Binding** (EU)	Not in Phase 1. In Phase 2 only if Art. 2(1) is triggered: placing the system on the EU market or putting it into service there, or, from a third country, its output being used in the Union. No EU establishment is needed
UNESCO Recommendation on the Ethics of AI (2021)	Non-binding (para. 2: voluntary)	Never directly; an ethical benchmark
OECD AI Principles (OECD/LEGAL/0449, revised 3 May 2024)	Non-binding Council Recommendation	Never directly; an ethical benchmark

Nigeria: what applies from launch

i. **Impact assessment (s.28; GAID Art. 28):** profiling, automated decisions with significant effects, sensitive data and financial services through digital devices each trigger a DPIA that must be filed with the regulator, signed by a certified DPO and completed before processing starts. All three modules qualify, so this is a launch gate.

ii. **Automated decisions (s.37):** people have a right not to be subject to decisions based solely on automated processing with significant effects, with safeguards of human intervention, expressing a view and contesting. Genuine staff review keeps decisions outside the right, but a regulator is likely to ask whether review is real, so rubber-stamping (ER5) creates legal as well as ethical risk.

iii. **Biometrics (s.30, s.65):** face matching, including one-to-one verification, is sensitive data and M1 needs consent. **Lawful basis (ss.25-26):** consent cannot be bundled into onboarding for behavioural data.

iv. **Fairness (s.24; GAID):** the GAID prohibits discrimination in processing and requires disparate-outcome assessment for AI, so Task 4-style testing is a compliance activity.

v. **Breach, transfers and penalties:** 72-hour breach notice; cross-border transfers need a recorded basis (ss.41-43); penalties reach the greater of ₦10 million and 2% of annual gross revenue (s.48(4)). SecureFinance very likely counts as a controller of major importance, adding DPO, registration and audit duties.

EU AI Act: Phase 2 classification

Classification depends on what each module does. M1 is probably not high-risk, because Annex III point 1(a) excludes biometric verification that only confirms a person is who they claim to be; one-to-many identification would change that. M2 is probably not high-risk, because point 5(b) excludes fraud detection. M3 is high-risk under point 5(b) on assumption A2, since it evaluates creditworthiness; limiting it to fraud or AML scoring would bring the exclusion into play.

Regulation (EU) 2026/1744, in force from 27 July 2026, moved the Annex III high-risk obligations to **2 December 2027**. Under Art. 111(2) as amended, a system already on the market is caught only after a significant design change, but I treat 2 December 2027 as the design target, because the fairness remediation recommended here is itself a design change. The Art. 5 prohibitions already apply; reusing M2 or M3 behavioural scores to penalise customers in unrelated contexts is the main exposure.

If M3 is high-risk, SecureFinance is both provider and deployer. As provider it must run a lifecycle risk management system with testing against thresholds defined in advance (Art. 9), govern data for bias examination and representativeness (Art. 10), and meet documentation, logging, transparency, human oversight, accuracy and cybersecurity duties (Arts. 11-16). As deployer it must assign oversight to people with competence and authority, keep logs for at least six months (Art. 26) and complete a fundamental rights impact assessment (Art. 27), for which the Nigerian DPIA is reusable input. Art. 14(4)(b) requires oversight that keeps reviewers aware of automation bias, the legal counterpart of ER5.

Soft law as a benchmark

UNESCO and the OECD set expectations above the legal floor. UNESCO paragraphs 28-29 (fairness, rural-urban equity, remedy), 32-34 and 74 (privacy, biometric security), 35-36 and 26 (human responsibility), 37-40 (transparency) and 27 (safety) line up with ER1-ER6. OECD Principle 1.2 covers fairness and privacy, 1.3 transparency including the ability to challenge outputs, 1.4 robustness including override mechanisms, and 1.5 accountability, traceability and risk management.

6. Fairness and explainability

Method. I evaluated M3 on a synthetic, seeded dataset of 8,000 customers (3,200 in the test set), comparing urban with rural, male with female and the intersection of rural women with urban men. Underlying creditworthiness is identical across groups, two proxy features (basic phone, location changes) relate to group but not to repayment, and past decisions are biased against basic-phone and thin-file customers. Because the data is synthetic, true repayment is known, which is unavailable for declined customers in reality (the selective-labels problem).

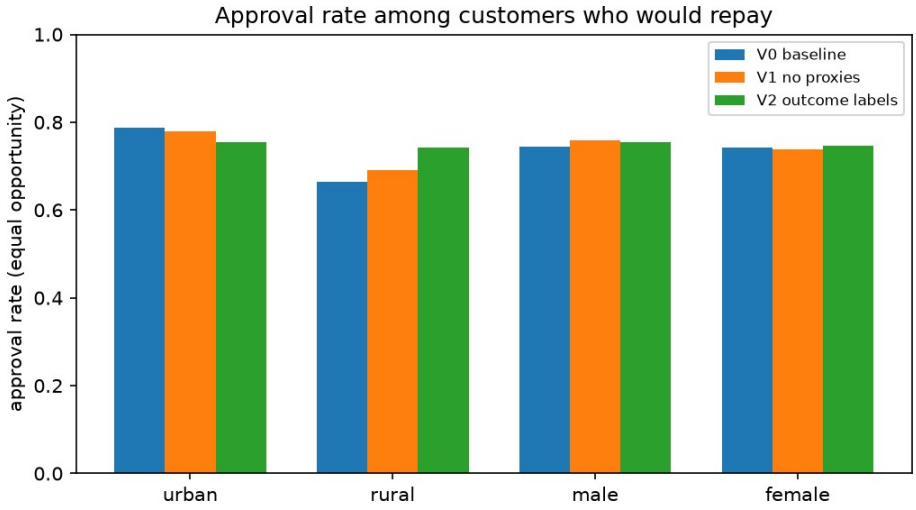
Measures. No single fairness definition is correct and they can conflict, so I use four. The *impact ratio* compares approval rates (the 0.8 rule of thumb is not a legal test). *Equal opportunity* compares approval among customers who would repay, directly measuring wrongful decline. The *false positive rate gap* compares approval among those who would not repay. *Predictive parity* compares repayment among those approved. Three variants were set to approve 62% overall: V0 baseline (all features, past decisions), V1 (proxies removed) and V2 (trained on repayment outcomes). Table 4 gives the results and Figure 1 shows the equal opportunity comparison. A clean-environment run of the code is shown in Appendix D.

Table 4: Fairness results for module M3 by comparison and model variant (pp = percentage points)

Comparison	Variant	Impact ratio	Equal opp. gap	FPR gap	Pred. parity gap
Rural vs urban	V0 baseline	**0.82**	**−12.3 pp**	−8.9 pp	+0.6 pp
Rural vs urban	V1 no proxies	0.88	−8.9 pp	−4.2 pp	−0.7 pp
Rural vs urban	V2 outcome labels	0.99	−1.2 pp	+2.5 pp	−2.0 pp
Rural women vs urban men	V0 baseline	0.81	−12.6 pp	−12.7 pp	+3.4 pp
Female vs male	V0 baseline	1.00	−0.2 pp	−1.7 pp	+1.5 pp

Bootstrap 95% intervals for the baseline rural vs urban comparison: impact ratio 0.77 to 0.87, equal opportunity gap −16.4 to −8.5 pp.

Figure 1: Approval rate among customers who would repay, by group and model variant (source: evidence/chart_equal_opportunity.png)



Findings.

i. **The baseline wrongly declines creditworthy rural customers.** The interval excludes zero, making this the clearest result.

ii. **Definitions disagree.** Predictive parity is almost perfect (+0.6 pp) while equal opportunity fails, so a team checking only precision would pass the model. The impact ratio of 0.82 also understates the harm, sitting just above 0.8 with an interval that crosses it.

iii. **The intersection is not shown to be worse on equal opportunity** (−12.6 vs −12.3 pp, well inside the ±4 pp interval). It is clearly worse only on the false positive rate gap (−12.7 vs −8.9 pp). There is no evidence of a gender gap, and that absence is also a result.

iv. **Removing proxies helps only partly** (V1), because label bias still enters through history length. Fixing the labels (V2) closes most of the gap, pointing to training data as the root cause.

Explainability. Permutation importance and coefficients show income stability dominating, as it should, while the basic-phone proxy ranks above history length and carries a negative coefficient: it penalises customers without any link to repayment. For decision review, 262 rural customers who would have repaid were wrongly declined by the baseline. Changing only the basic-phone flag would have approved 48% of them, so a reviewer should escalate any decision that flips on a proxy alone.

Limits. The data is synthetic with planted bias, so it shows the method, not real-world prevalence. Only M3 and two group attributes were tested; M1 and M2 need group-level error rates measured on pilot data. A simple logistic model keeps explanations exact; complex models would need tools such as SHAP. Group-specific thresholds could narrow gaps but risk unlawful differential treatment and are not recommended without legal advice.

7. Prioritised recommendations

Table 5: Prioritised recommendations with owner and timing

No.	Action	Owner	When
i	Complete and file the DPIA with the regulator, signed by a certified DPO, covering all three modules	DPO; Legal	Before any launch
ii	Set the equal-opportunity gap threshold (for example 5 pp, with confidence intervals) and make it a go-live gate for M3	AI Governance Committee	Before testing
iii	Retrain M3 on outcome labels, using a controlled approval sample; block device-type and location-change features	Head of Data Science	Before M3 leaves shadow mode
iv	Measure group-level error rates for M1 and M2 on pilot data and report false positive rates by group monthly	Head of Data Science; Customer Ops	During pilot
v	Operate reason codes, notice of AI use, a named appeal route and human determination for severe decisions	Head of Customer Operations	Before pilot
vi	Train reviewers on automation bias, give them authority to override, and track override rates	Fraud Ops Manager; Training	Before pilot
vii	Fix biometric retention, separate encrypted storage and rehearse the 72-hour breach runbook	CISO; DPO	Before pilot
viii	Confirm M3's EU classification with legal counsel	Head of Legal & Compliance	Before any EU step

8. Deployment recommendation

A conditional, staged go. A full launch is not justified, because the central controls do not yet exist and the fairness evidence shows a plausible, material harm. A blanket no-go would also be disproportionate, since M1 and M2 carry lower fairness exposure and the main risks have defined controls.

i. **M3, shadow mode only.** M3 produces scores without affecting any customer until its equal-opportunity gap passes the Committee's threshold on outcome-labelled data, with the Task 4 controls in place. It is the module with the strongest fairness evidence of harm and the one most likely to be high-risk in the EU.

ii. **M1 and M2, Nigerian pilot.** Proceed behind the seven launch gates (Appendix B), including DPIA approval, fairness testing within pre-set thresholds, a working appeals route and a tested switch-off. M1 and M2 were not fairness-tested here, so the pilot itself must produce that evidence.

iii. **EU phase, no-go for now.** Re-open only when Legal confirms M3's classification and the design meets the Act's high-risk requirements ahead of 2 December 2027.

This recommendation changes if the Committee's gap threshold is not met on outcome-labelled data, if the DPIA identifies unmitigable high residual risk (which would require consulting the regulator), or if M3 is narrowed to fraud scoring, which would remove its high-risk classification.

References

[1] Federal Republic of Nigeria. *Nigeria Data Protection Act 2023.* Nigeria Data Protection Commission, https://ndpc.gov.ng/.

[2] Nigeria Data Protection Commission. *NDPA General Application and Implementation Directive (GAID) 2025.* https://ndpc.gov.ng/

[3] European Union. *Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act).* Official Journal L, 12 July 2024. AI Act Explorer: https://ai-act-service-desk.ec.europa.eu/en/ai-act-explorer

[4] European Union. *Regulation (EU) 2026/1744 (Digital Omnibus on AI)*, in force 27 July 2026. European Commission announcement: https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force

[5] UNESCO. *Recommendation on the Ethics of Artificial Intelligence*, adopted 23 November 2021. https://www.unesco.org/en/legal-affairs/recommendation-ethics-artificial-intelligence

[6] OECD. *Recommendation of the Council on Artificial Intelligence*, OECD/LEGAL/0449, as amended 3 May 2024. https://legalinstruments.oecd.org/public/doc/648/648.en.pdf

[7] National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1, January 2023. https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf

[8] Schwartz, R., et al. *Towards a Standard for Identifying and Managing Bias in Artificial Intelligence*, NIST Special Publication 1270, March 2022. National Institute of Standards and Technology.

[9] Synthetic data, code and evidence: repository *AICS-201-AI-Ethics-Governance-and-Legal-Compliance-Assessment* (analysis/, data/, evidence/, risk_register/).

Appendix A. AI risk register (12 risks)

Table 6: AI risk register: 12 risks with likelihood × impact (inherent → residual), owner and ratings

ID	Category	Description	Likelihood × impact	Owner	Inherent	Residual
RR01	Bias	Model error or rejection rates differ materially across customer groups because training data is unrepresentative or historically skewed (M1, M2, M3).	4×4 → 2×4	Head of Data Science	16 Critical	8 Medium
RR02	Fairness	Proxy features (location, device, network, language, name patterns) reproduce discrimination without using protected attributes.	4×4 → 2×4	Head of Data Science	16 Critical	8 Medium
RR03	Privacy	Excessive collection, retention or reuse of biometric and financial data; unauthorised access.	3×5 → 2×4	Data Protection Officer	15 Critical	8 Medium
RR04	Transparency	Customers and staff cannot understand or contest AI-informed decisions.	4×3 → 2×3	Head of Customer Operations	12 High	6 Medium
RR05	Human oversight	Reviewers accept model outputs by default (automation bias), so oversight exists only on paper.	4×4 → 3×3	Fraud Operations Manager	16 Critical	9 Medium
RR06	Fairness / accountability	False positives block or freeze legitimate customers, concentrated on already-flagged groups, with slow or no remedy.	4×4 → 3×3	Head of Customer Operations	16 Critical	9 Medium

ID	Category	Description	Likelihood × impact	Owner	Inherent	Residual
RR07	Performance	Model drift and feedback loops: fraud patterns change, and flagged cases are fed back as training labels, degrading accuracy and amplifying bias.	4×3 → 2×3	Head of Data Science	12 High	6 Medium
RR08	Security	Compromise of the biometric store or models, or attacks on identity checks (spoofed or synthetic faces, document forgery).	3×5 → 2×4	Chief Information Security Officer	15 Critical	8 Medium
RR09	Third party	Dependency on external identity databases, cloud services or pre-trained components that fail, change, or carry their own bias or legal risk.	3×3 → 2×3	Vendor Risk Manager	9 Medium	6 Medium
RR10	Legal compliance	Failure to identify when binding obligations apply (Nigeria Data Protection Act 2023; EU AI Act if the EU trigger is met), including cross-border data transfers.	3×5 → 2×4	Head of Legal & Compliance	15 Critical	8 Medium
RR11	Governance	Unclear ownership and slow escalation when the system causes harm, so incidents are not contained or communicated.	3×4 → 2×3	Chief Risk Officer	12 High	6 Medium
RR12	Capability	Staff operating or overseeing the system lack the AI literacy to use outputs responsibly.	3×3 → 2×2	Head of Human Resources / Training	9 Medium	4 Low

Controls, NIST function references and control status for each risk are in risk_register/risk_register.csv. Scores are likelihood × impact out of 25 (Low 1-4, Medium 5-9, High 10-14, Critical 15-25); residual scores assume proposed controls are in place and working. The likelihood × impact column shows inherent → residual.

Appendix B. Launch gates

i. Group-level fairness testing completed and within thresholds the Committee set beforehand.

ii. DPIA completed, signed by the DPO and filed with the regulator.

iii. Reason codes, appeals route and human determination rules operating in a pilot.

iv. Penetration and anti-spoofing tests passed; incident runbook rehearsed.

v. Legal applicability review signed off for each launch market.

vi. Reviewer training completed and competence checked.

vii. Switch-off procedure tested.

Appendix C. Reproducing the fairness analysis

From the repository root: python3 -m venv .venv && source .venv/bin/activate && pip install -r requirements.txt, then python analysis/generate_data.py (writes data/synthetic_customers.csv with a fixed seed) and python analysis/fairness_analysis.py (writes group metrics, gap summary, importance table, decision-review sheet, charts and summary.txt to evidence/). Headline figures in section 6 come from evidence/gap_summary.csv and evidence/summary.txt.

Appendix D. Evidence: clean-environment run of the analysis

The figures below show the analysis reproduced from a fresh virtual environment on 9 November 2026, using the repository as submitted. The metrics in Figure 5 match section 6 and evidence/gap_summary.csv (for example, rural vs urban V0: impact ratio 0.823, equal opportunity gap −0.123, false positive rate gap −0.089, bootstrap interval −0.164 to −0.085). The original files are in evidence/screenshots/.

Figure 2: Creating a virtual environment and starting the installation of requirements.txt (pandas, numpy, scikit-learn, matplotlib)

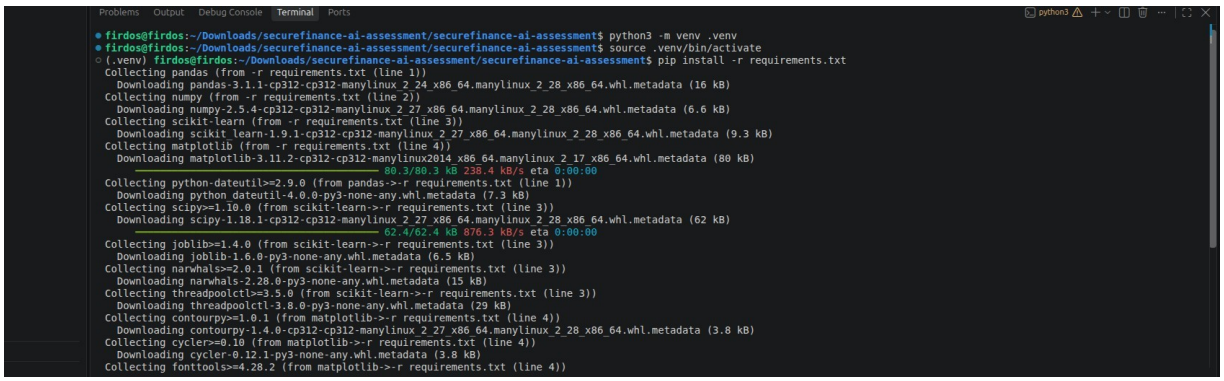


Figure 3: Dependency installation completing successfully

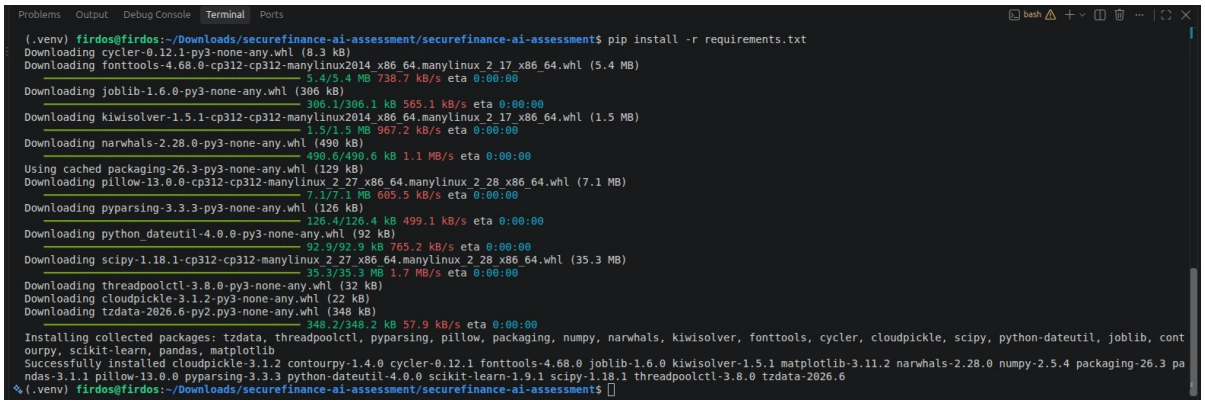


Figure 4: Running analysis/generate_data.py, which writes the 8,000-row synthetic dataset (no real customer data)

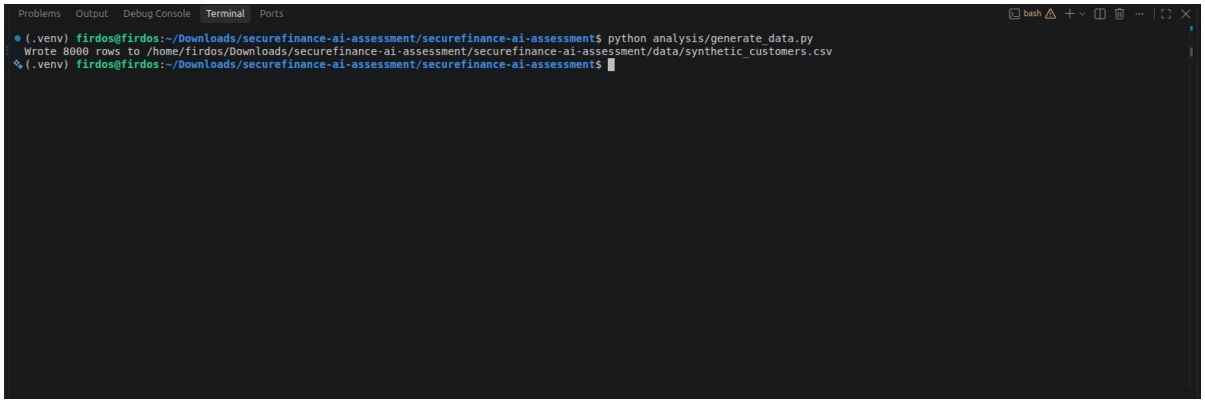


Figure 5: Running analysis/fairness_analysis.py: fairness metrics for the three model variants, bootstrap interval, feature importance and the decision-review result (262 wrongly declined rural customers; 47.7% approved if only the basic-phone flag is changed)

